
**CONCEPTO
ARQUITECTURA EMPRESARIAL
DATOS SENSIBLES DE TARJETA EN CREACIÓN
CREDIBANCO
VERSIÓN 1.0**

HISTORIA DE REVISIONES

Fecha	Versión	Descripción	Autor
30/04/2026	1.0	Versión Inicial	Javier Riardo Agudelo

TABLA DE CONTENIDO

HISTORIA DE REVISIONES	2
TABLA DE CONTENIDO	3
GUÍA DE USO	4
NECESIDAD.....	5
PREMISAS DEL CONCEPTO	6
LINEAMIENTOS	7
RESTRICCIONES	9
ARQUITECTURA PROPUESTA	10
Diagrama de Arquitectura.....	11
Descripción de componentes	12
Descripción del proceso.....	13
Tratamiento propuesto por tipo de dato	18
Riesgos identificados	18
Aplicaciones y/o soluciones afectadas	19
ANEXOS	22

GUÍA DE USO

El presente documento detalla el concepto del equipo de arquitectura empresarial generado para la necesidad expuesta por el negocio. Se identifica la necesidad, premisas, lineamientos, restricciones y se detalla la arquitectura propuesta.

A su vez, contiene el detalle de los elementos evaluados y el análisis a alto nivel de los posibles componentes involucrados dentro de Credibanco.

Cómo diligenciar este documento:

- No se deben eliminar las anotaciones al inicio de cada sección con información de lo que debe contener cada punto. Estas notas sirven para ayudar a determinar la información a rellenar y para ayudar a las personas que revisan el documento a saber que debe estar cumplimentado en cada apartado.
- No se deben eliminar puntos del índice o capítulos del documento. Si algún punto no aplica se pondrá el comentario "NO APLICA".
- No olvide actualizar la fecha y la versión del documento en el encabezado, y el nombre del archivo en el pie de página.
- Tenga la precaución de revisar todos los encabezados y pies de página del documento para confirmar que la información que figura en los mismos está correctamente actualizada, ya que hay encabezados y pies de página para diferentes secciones del documento, y para páginas pares e impares.

NECESIDAD

El presente concepto se enfoca en definir la arquitectura propuesta para el manejo seguro de datos sensibles de tarjeta durante el proceso de creación de tarjetas prepago, contemplando el cifrado inmediato del PAN mediante HSM y el descarte del CVV2 recibido desde el proveedor Pomelo.

La necesidad surge porque, durante la creación de una tarjeta prepago por archivo batch o por API, el Orchestrator de creación interactúa con Pomelo para crear el cliente, crear la tarjeta y consultar los datos sensibles asociados a la tarjeta generada. En este proceso, el sistema recibe información de tarjeta que puede incluir PAN completo, fecha de vencimiento y CVV2.

Dado que el PAN completo corresponde a información sensible de tarjeta y entra en alcance de cumplimiento PCI, la arquitectura debe garantizar que dicho dato sea tratado de forma controlada, cifrado inmediatamente, almacenado únicamente en forma protegida y nunca expuesto en logs, archivos, caché o componentes no autorizados.

De igual forma, el CVV2 recibido durante la consulta de datos sensibles no debe almacenarse en ningún sistema de Credibanco. Su tratamiento debe limitarse al proceso transitorio estrictamente necesario, descartándolo inmediatamente después de recibido y evitando su persistencia en base de datos, logs, archivos, colas, cachés o herramientas de observabilidad. Las necesidades principales son:

- Definir el tratamiento seguro de PAN, fecha de vencimiento, BIN, últimos 4 dígitos, card token y CVV2 durante la creación de tarjetas prepago.
- Cifrar el PAN completo inmediatamente después de recibirlo desde Pomelo.
- Utilizar HSM Thales payShield como componente criptográfico para el cifrado del PAN.
- Almacenar el PAN únicamente en formato cifrado dentro de Oracle.
- Generar un identificador de búsqueda del PAN sin exponer el PAN en claro.
- Evitar el uso de hash simple del PAN y adoptar un mecanismo más robusto, como HMAC-SHA-256 con llave secreta custodiada.
- Extraer y almacenar únicamente los datos operativos permitidos, como BIN y últimos 4 dígitos.
- Definir si la fecha de vencimiento debe almacenarse cifrada, recomendando su cifrado por postura conservadora de seguridad.
- Descartar inmediatamente el CVV2 sin almacenamiento permanente.
- Garantizar que el PAN en claro exista únicamente en memoria del proceso durante el tiempo estrictamente necesario para su cifrado.
- Evitar que PAN o CVV2 sean escritos en logs, archivos temporales, caché, trazas, colas o herramientas de monitoreo.
- Delimitar claramente los componentes dentro del CDE.
- Obtener validación de Seguridad de la Información sobre el modelo propuesto y su compatibilidad con la próxima auditoría PCI.

PREMISAS DEL CONCEPTO

Esta sección presenta las premisas que rigen la arquitectura propuesta para el manejo de datos sensibles durante la creación de tarjetas prepago.

- La creación de tarjetas prepago podrá originarse desde dos canales: archivo batch o consumo de API.
- El canal batch recibirá archivos desde la entidad emisora a través de SFTP y GoAnywhere MFT.
- El canal API recibirá solicitudes de creación desde la entidad emisora mediante endpoints expuestos por el gateway correspondiente.
- El Orchestrator de creación será el componente responsable de coordinar la creación del cliente, creación de tarjeta y consulta de datos sensibles contra Pomelo.
- Pomelo será el proveedor que retorna el card_id, card_token, PAN completo, fecha de vencimiento y CVV2 durante el proceso de creación de tarjeta.
- El PAN completo recibido desde Pomelo se considera dato sensible de tarjeta y debe tratarse dentro del alcance CDE.
- El backend que recibe temporalmente el PAN completo desde Pomelo se considera componente dentro del CDE.
- El PAN completo no deberá almacenarse en claro en ninguna base de datos, archivo, log, caché, cola o almacenamiento temporal.
- El PAN deberá cifrarse inmediatamente mediante HSM Thales payShield antes de persistirse.
- La llave utilizada para cifrar PAN deberá estar custodiada bajo el HSM y no deberá salir en claro del hardware criptográfico.
- El PAN cifrado será almacenado en Oracle en el campo correspondiente, por ejemplo pan_encrypted.
- Para búsquedas operativas, no se deberá usar PAN en claro.
- El identificador de búsqueda del PAN deberá generarse mediante un mecanismo irreversible y protegido, preferiblemente HMAC-SHA-256 con llave secreta custodiada en HSM.
- Los últimos 4 dígitos del PAN podrán almacenarse en claro para propósitos operativos y de visualización parcial.
- El BIN, primeros 6 u 8 dígitos, podrá almacenarse en claro para propósitos de ruteo, clasificación y reglas operativas.
- La fecha de vencimiento deberá protegerse, recomendando su almacenamiento cifrado por estar asociada a datos de tarjeta.
- El card_token entregado por Pomelo podrá almacenarse como identificador/token del proveedor, siempre que no permita reconstruir el PAN.
- El CVV2 recibido desde Pomelo no deberá almacenarse en ningún sistema de Credibanco.
- El CVV2 no deberá escribirse en logs, trazas, archivos, base de datos, caché, colas o herramientas de monitoreo.
- El CVV2 deberá descartarse inmediatamente después de recibido.
- Para visualización posterior de datos de tarjeta, el CVV2 deberá obtenerse dinámicamente desde Pomelo, de acuerdo con el diseño de visualización mediante iframe seguro.
- Los componentes que reciben, procesan, cifran o almacenan PAN deberán considerarse dentro del alcance CDE propuesto.
- Todo el flujo deberá generar auditoría sin incluir PAN completo, CVV2 ni payloads sensibles.

LINEAMIENTOS

Esta sección presenta los lineamientos que rigen la arquitectura propuesta.

- La solución deberá aplicar el principio de mínima exposición de datos sensibles durante todo el proceso de creación de tarjetas.
- El PAN completo recibido desde Pomelo deberá cifrarse inmediatamente antes de ser persistido.
- El PAN completo no deberá almacenarse en claro bajo ninguna circunstancia.
- El PAN completo no deberá registrarse en logs técnicos, logs funcionales, trazas distribuidas, herramientas APM, mensajes de error, archivos temporales, colas o caché.
- El cifrado del PAN deberá realizarse mediante HSM Thales payShield o componente criptográfico aprobado por Seguridad de la Información.
- La llave de cifrado del PAN deberá permanecer custodiada bajo HSM y no deberá exponerse en claro a la aplicación.
- El almacenamiento del PAN deberá realizarse únicamente en formato cifrado.
- El algoritmo de cifrado propuesto será AES-256-GCM o el estándar corporativo aprobado para protección de datos sensibles.
- El proceso de cifrado deberá ejecutarse dentro del perímetro CDE.
- El PAN en claro solo podrá existir en memoria volátil durante el tiempo estrictamente necesario para invocar el cifrado.
- Después del cifrado, las referencias en memoria que contengan PAN deberán limpiarse o descartarse de forma controlada.
- El CVV2 no deberá almacenarse, aun cuando se proponga cifrado.
- El CVV2 deberá descartarse inmediatamente después de recibido desde Pomelo.
- El CVV2 no deberá formar parte de estructuras persistentes, eventos, payloads de auditoría, logs, respuestas API internas o archivos de salida.
- El CVV2 requerido para visualización posterior deberá consultarse directamente a Pomelo y no obtenerse desde almacenamiento local.
- La fecha de vencimiento deberá almacenarse cifrada, salvo que Seguridad de la Información apruebe expresamente un tratamiento distinto.
- Los últimos 4 dígitos del PAN podrán almacenarse en claro para soporte operativo, identificación visual y conciliación.
- El BIN podrá almacenarse en claro para ruteo, clasificación, reglas de negocio y validaciones operativas.
- Para búsquedas por PAN no deberá utilizarse PAN en claro.
- El valor de búsqueda del PAN deberá generarse mediante HMAC-SHA-256 o mecanismo equivalente con secreto custodiado, evitando SHA-256 simple sin salt o sin llave.
- El card_token de Pomelo deberá almacenarse únicamente como referencia del proveedor y no deberá considerarse sustituto de controles de seguridad sobre PAN.
- Todo acceso administrativo o técnico a los componentes que procesen PAN deberá regirse por mínimo privilegio, segregación de funciones y trazabilidad.
- Las integraciones con Pomelo deberán realizarse por canales seguros, con autenticación fuerte, mTLS o el estándar definido para la integración.
- Las respuestas de Pomelo que contengan datos sensibles deberán tratarse como payloads sensibles y excluirse de logging automático.
- Se deberán configurar filtros de logging y mascaramiento para impedir la exposición accidental de PAN o CVV2.
- La persistencia en Oracle deberá incluir únicamente datos permitidos y protegidos: PAN cifrado, identificador de búsqueda protegido, BIN, últimos 4 dígitos, fecha de vencimiento cifrada, card token y metadatos operativos.
- La arquitectura deberá generar auditoría de creación, cifrado y persistencia sin incluir datos sensibles.
- Cualquier error durante la creación, cifrado o persistencia deberá manejarse sin exponer datos sensibles en mensajes técnicos o funcionales.

- En caso de falla de cifrado del PAN, la tarjeta no deberá quedar persistida con PAN en claro ni en estado inconsistente.
- La solución deberá contar con controles de idempotencia para evitar duplicidad de creación de clientes o tarjetas.
- La compatibilidad del diseño con PCI DSS deberá ser validada formalmente por Seguridad de la Información.

RESTRICCIONES

Esta sección presenta las restricciones que rigen la arquitectura propuesta.

- El proceso de creación de tarjeta depende de la disponibilidad de Pomelo para la creación de cliente, creación de tarjeta y consulta de datos sensibles.
- El proceso depende de la disponibilidad del HSM Thales payShield para cifrar el PAN antes de su almacenamiento.
- Si el HSM no se encuentra disponible, el sistema no deberá persistir PAN en claro ni continuar el flujo de almacenamiento de tarjeta.
- El PAN completo no puede ser almacenado en claro en Oracle ni en ningún otro repositorio.
- El PAN completo no puede registrarse en logs, trazas, mensajes de error, archivos temporales, colas o herramientas APM.
- El CVV2 no puede ser almacenado en ningún sistema de Credibanco.
- El CVV2 no puede ser usado como dato persistente para consultas posteriores.
- El CVV2 no puede enviarse a componentes no autorizados ni incluirse en auditoría.
- El backend que recibe PAN completo desde Pomelo debe considerarse dentro del alcance CDE.
- Oracle deberá considerarse dentro del alcance aplicable en la medida en que almacena PAN cifrado y metadatos asociados.
- El uso de SHA-256 simple para búsquedas por PAN no es recomendable y debe ser validado o reemplazado por HMAC-SHA-256 con llave secreta.
- La fecha de vencimiento no debería almacenarse en claro sin validación expresa de Seguridad de la Información.
- El proceso debe garantizar que no existan volcados de memoria, dumps, logs de debug o trazas que puedan contener PAN o CVV2.
- El flujo batch y el flujo API deben aplicar el mismo tratamiento de datos sensibles.
- Las diferencias de canal de entrada no deberán generar diferencias en los controles de cifrado, descarte, auditoría o persistencia.
- Cualquier reproceso de archivo batch deberá evitar duplicidad y exposición de datos sensibles.
- Los archivos de entrada enviados por la entidad no deben contener PAN generado por Pomelo, pero sí pueden contener datos del cliente requeridos para crear la tarjeta.
- El archivo de respuesta a la entidad no deberá incluir PAN completo en este flujo, salvo que exista un diseño separado aprobado para generación de archivos con PAN.
- La solución deberá contar con controles para evitar que payloads sensibles queden registrados por librerías HTTP, interceptores, gateways, proxies o herramientas de monitoreo.
- La compatibilidad con la próxima auditoría PCI no se considera automática y deberá validarse formalmente.

ARQUITECTURA PROPUESTA

La arquitectura propuesta define el tratamiento seguro de los datos sensibles recibidos durante la creación de tarjetas prepago, tanto por canal batch como por canal API.

El flujo inicia cuando la entidad emisora solicita la creación de tarjetas. Para el canal batch, la entidad deposita archivos en el SFTP, GoAnywhere MFT valida estructura y formato, y posteriormente los archivos son ubicados en el almacenamiento de entrada para su procesamiento. Para el canal API, la entidad consume los endpoints publicados a través del gateway de Prepago.

Ambos canales convergen en el Prepaid Card Creation Orchestrator, componente responsable de ejecutar la lógica de negocio para la creación de cliente y tarjeta contra Pomelo, así como de consultar los datos sensibles generados por el proveedor.

Una vez Pomelo retorna el PAN completo, fecha de vencimiento y CVV2, el Orchestrator ejecuta el tratamiento de datos sensibles bajo el siguiente modelo:

1. Recibe PAN, fecha de vencimiento y CVV2 desde Pomelo.
2. Invoca el HSM Thales payShield para cifrar inmediatamente el PAN mediante AES-256-GCM.
3. Genera un identificador de búsqueda protegido del PAN mediante HMAC-SHA-256.
4. Extrae últimos 4 dígitos y BIN para operación.
5. Cifra la fecha de vencimiento o la trata según definición aprobada por Seguridad.
6. Descarta inmediatamente el CVV2.
7. Limpia referencias de PAN y CVV2 en memoria.
8. Persiste en Oracle únicamente datos permitidos: PAN cifrado, HMAC del PAN, BIN, últimos 4, fecha de vencimiento protegida, card_id, card_token, estado y metadatos operativos.
9. Registra auditoría sin datos sensibles.

Diagrama de Arquitectura

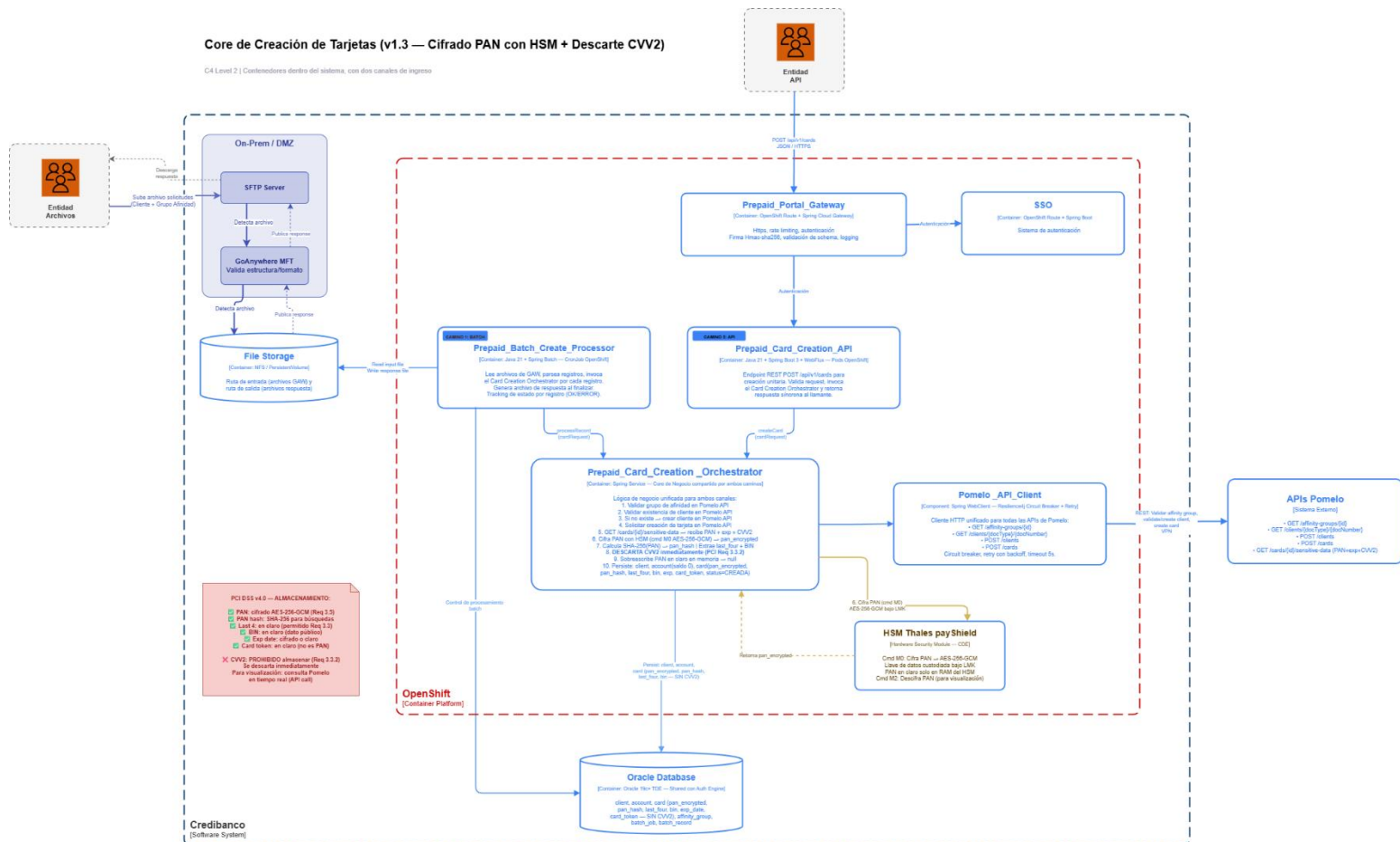


Diagrama 1. – Diagrama de Arquitectura

Descripción de componentes

Identificador	Componente	Descripción
CSA-001	Entidad emisora	Actor externo que solicita la creación de tarjetas por archivo batch o API.
CSA-002	SFTP Server	Canal de recepción de archivos batch desde la entidad emisora.
CSA-003	GoAnywhere MFT	Componente responsable de validar estructura/formato y mover archivos al almacenamiento de procesamiento.
CSA-004	File Storage	Repositorio de entrada y salida para archivos batch procesados.
CSA-005	Prepaid Portal Gateway	Gateway de entrada para solicitudes API de creación de tarjetas. Realiza validaciones, autenticación, control de esquema y logging controlado.
CSA-006	SSO	Sistema de autenticación usado para validar consumos API autorizados.
CSA-007	Prepaid Batch Create Processor	Procesador batch que lee archivos, valida registros y envía solicitudes de creación al Orchestrator.
CSA-008	Prepaid Card Creation API	API de creación de tarjetas usada para solicitudes transaccionales desde entidad.
CSA-009	Prepaid Card Creation Orchestrator	Componente central que orquesta creación de cliente, creación de tarjeta, consulta de datos sensibles, cifrado, descarte y persistencia.
CSA-010	Pomelo API Client	Cliente HTTP seguro para consumir APIs de Pomelo con control de timeout, retry, circuit breaker y logging sanitizado.
CSA-011	APIs Pomelo	Servicios externos para creación de cliente, creación de tarjeta y consulta de datos sensibles.
CSA-012	HSM Thales payShield	Componente criptográfico usado para cifrado del PAN y custodia de llaves.
CSA-013	Oracle Database	Base de datos donde se persiste PAN cifrado, HMAC del PAN, BIN, últimos 4, fecha de vencimiento protegida, tokens y estado de tarjeta.
CSA-014	Plataforma de auditoría	Servicio o capacidad de registro de eventos del proceso sin incluir PAN completo ni CVV2.

Tabla 1. – Listado Responsabilidades de Componentes

Descripción del proceso

Esta sección describe el proceso propuesto para el manejo seguro de datos sensibles de tarjeta durante la creación de tarjetas prepago, contemplando los dos canales de ingreso definidos: archivo batch y API, y el tratamiento posterior del PAN, fecha de vencimiento y CVV2 recibidos desde Pomelo.

El proceso tiene como objetivo garantizar que el PAN completo sea cifrado inmediatamente mediante HSM antes de persistirse, que el CVV2 sea descartado sin almacenamiento, y que únicamente se conserven en Oracle los datos estrictamente necesarios para la operación, bajo los controles de seguridad definidos.

1. Recepción de solicitud de creación de tarjeta

La creación de tarjetas prepago puede originarse por dos canales:

Canal batch

La entidad emisora deposita un archivo de solicitud de creación de tarjetas en el servidor SFTP dispuesto para el proceso.

Posteriormente, GoAnywhere MFT detecta el archivo, lo descifra, valida su estructura y formato, y lo publica en el almacenamiento definido para procesamiento batch.

El archivo queda disponible para ser leído por el componente Prepaid Batch Create Processor, responsable de procesar los registros contenidos en el archivo.

Canal API

La entidad emisora consume el endpoint expuesto por el Prepaid Portal Gateway para solicitar la creación de una tarjeta de forma transaccional.

El gateway realiza validaciones iniciales de autenticación, autorización, firma, esquema del mensaje y trazabilidad antes de enviar la solicitud al componente de creación correspondiente.

2. Validación inicial de la solicitud

Dependiendo del canal de entrada, la solicitud es procesada por uno de los siguientes componentes:

- **Prepaid Batch Create Processor**, para solicitudes provenientes de archivo batch.
- **Prepaid Card Creation API**, para solicitudes recibidas por API.

En ambos casos, se ejecutan validaciones iniciales sobre la información recibida, tales como:

- Validación de estructura del registro o payload.
- Validación de campos obligatorios.
- Validación de entidad emisora.
- Validación de producto o tipo de tarjeta.
- Validación de duplicidad.
- Validación de idempotencia.
- Generación o propagación del correlationId.

Una vez superadas las validaciones iniciales, la solicitud es enviada al Prepaid Card Creation Orchestrator, componente responsable de coordinar el proceso completo de creación.

3. Orquestación de creación de cliente y tarjeta en Pomelo

El Prepaid Card Creation Orchestrator inicia la integración con Pomelo a través del Pomelo API Client.

El proceso contempla las siguientes operaciones:

1. Crear el cliente en Pomelo mediante el servicio correspondiente.
2. Crear la tarjeta en Pomelo.
3. Recibir como respuesta el card_id y el card_token.
4. Consultar los datos sensibles de la tarjeta generada mediante el endpoint de datos sensibles de Pomelo.

Durante esta fase, el Orchestrator mantiene control transaccional del proceso, registrando estados intermedios y garantizando que no se genere duplicidad ante reintentos o reprocesos.

4. Recepción de datos sensibles desde Pomelo

Después de crear la tarjeta, el Orchestrator consulta los datos sensibles generados por Pomelo.

La respuesta puede incluir:

- PAN completo.
- Fecha de vencimiento.
- CVV2.
- Identificadores asociados a la tarjeta.

Desde este punto, el flujo entra en tratamiento de datos sensibles de tarjeta, por lo que el Orchestrator, el canal de comunicación, el HSM y los componentes de persistencia asociados se consideran dentro del alcance CDE propuesto.

La respuesta recibida desde Pomelo no debe ser registrada en logs, trazas, herramientas APM, archivos temporales, colas ni mensajes de error.

5. Cifrado inmediato del PAN mediante HSM

Una vez recibido el PAN completo, el Orchestrator invoca el HSM Thales payShield para cifrar el PAN antes de cualquier persistencia.

El cifrado se realiza mediante el comando correspondiente del HSM, usando AES-256-GCM o el mecanismo aprobado por Seguridad de la Información.

El proceso debe cumplir las siguientes condiciones:

- El PAN completo solo existe en memoria del proceso durante el tiempo estrictamente necesario para enviarlo al HSM.
- La llave de cifrado permanece custodiada bajo el HSM y no sale en claro del hardware criptográfico.
- El resultado de la operación es un valor cifrado, por ejemplo pan_encrypted.
- El PAN en claro no se almacena en base de datos, archivos, logs, cachés ni colas.
- Si el HSM no está disponible o la operación de cifrado falla, el proceso no debe persistir la tarjeta con PAN en claro.

6. Generación de identificador protegido para búsqueda del PAN

Después de recibir el PAN, y antes de limpiar las referencias en memoria, el sistema genera un identificador protegido para búsquedas operativas.

Se recomienda que este identificador no sea un hash simple tipo SHA-256(PAN), sino un valor generado mediante:

HMAC-SHA-256(PAN, llave secreta custodiada en HSM/KMS)

Este valor permite búsquedas determinísticas sin requerir el PAN en claro y reduce el riesgo de ataques por diccionario o fuerza bruta en caso de exposición de la base de datos.

El resultado se persiste en Oracle como pan_hmac o campo equivalente.

7. Extracción de datos operativos permitidos

El Orchestrator extrae del PAN los datos estrictamente necesarios para operación:

- Últimos 4 dígitos del PAN.
- BIN, primeros 6 u 8 dígitos.

Estos datos pueden almacenarse en claro para propósitos operativos, tales como identificación visual parcial, reglas de ruteo, clasificación de producto, conciliación o soporte. La extracción debe realizarse antes de limpiar las referencias del PAN en memoria.

8. Tratamiento de la fecha de vencimiento

La fecha de vencimiento recibida desde Pomelo debe tratarse como dato asociado a la tarjeta.

Por postura conservadora de seguridad, se recomienda almacenarla cifrada, especialmente porque puede correlacionarse con otros atributos como BIN, últimos 4 dígitos, card_id o card_token.

El dato puede persistirse como:

- exp_date_encrypted, si se adopta cifrado.
- Campo equivalente definido por el modelo de datos aprobado.

La decisión final sobre almacenar la fecha de vencimiento cifrada o en claro deberá ser validada por Seguridad de la Información.

9. Descarte inmediato del CVV2

El CVV2 recibido desde Pomelo no debe almacenarse bajo ninguna circunstancia.

El Orchestrator debe descartarlo inmediatamente después de recibido, garantizando que:

- No se persista en Oracle.
- No se registre en logs.
- No se envíe a otros componentes internos.
- No se almacene en caché.
- No se publique en colas o eventos.
- No se incluya en auditoría.
- No se conserve en archivos temporales.
- No sea expuesto en mensajes de error o trazas.

El descarte debe realizarse limpiando la referencia en memoria o asignando valor nulo a la variable correspondiente, según el lenguaje y prácticas de implementación aplicables.

Para futuras visualizaciones del CVV2 por parte del tarjetahabiente, el dato deberá obtenerse dinámicamente desde Pomelo, en tiempo real, según el diseño independiente del iframe de visualización segura de datos sensibles.

10. Limpieza de datos sensibles en memoria

Después de cifrar el PAN, generar el identificador protegido de búsqueda, extraer los últimos 4 dígitos, extraer el BIN y descartar el CVV2, el Orchestrator debe limpiar las referencias a datos sensibles en memoria.

Esta limpieza aplica especialmente sobre:

- PAN completo.
- CVV2.
- Payload completo recibido desde Pomelo.
- Objetos temporales que contengan datos sensibles.
- Variables intermedias usadas para cifrado o transformación.

Adicionalmente, se deberán evitar configuraciones que generen volcados de memoria, heap dumps, logs de debug o trazas técnicas que puedan contener datos sensibles.

11. Persistencia segura en Oracle

Una vez aplicado el tratamiento de datos sensibles, el Orchestrator persiste en Oracle únicamente los datos permitidos y protegidos.

La información a persistir incluye, según el modelo aprobado:

- card_id.
- card_token.
- pan_encrypted.
- pan_hmac o identificador protegido equivalente.
- last_four.
- bin.
- exp_date_encrypted o campo de fecha de vencimiento según definición aprobada.
- Estado de la tarjeta.
- Identificador de entidad.
- Identificador de producto.
- Metadatos operativos.
- Estado del proceso batch o API.
- Trazabilidad del proceso.

No se debe persistir:

- PAN en claro.
- CVV2.
- Payload completo de Pomelo.
- Datos sensibles en campos de observación, descripción, error o auditoría.

12. Actualización de estado de la tarjeta

Después de persistir la información protegida, el sistema actualiza el estado de la tarjeta y del proceso de creación.

Dependiendo del resultado, la tarjeta podrá quedar en estados como:

- Creada.
- Pendiente de activación.
- Rechazada.
- En error técnico.
- Pendiente de reproceso.
- Fallida por error de integración.
- Fallida por error criptográfico.

Si ocurre una falla durante el cifrado o la persistencia, el sistema debe aplicar un comportamiento seguro:

- No almacenar PAN en claro.
- No almacenar CVV2.
- Registrar el error sin datos sensibles.
- Mantener trazabilidad para reproceso o conciliación.
- Evitar duplicidad mediante controles de idempotencia.

13. Generación de respuesta al canal de origen

Una vez finalizado el procesamiento, el sistema genera la respuesta correspondiente al canal de origen.

Para canal batch

El Prepaid Batch Create Processor consolida el resultado de cada registro procesado y genera el archivo de respuesta correspondiente, sin incluir PAN completo ni CVV2 en este flujo.

El archivo de respuesta puede incluir:

- Identificador del registro.
- Estado de procesamiento.
- Código de resultado.
- Mensaje funcional.
- Identificador de tarjeta, si aplica.
- Información no sensible permitida.

Para canal API

El Prepaid Card Creation API retorna la respuesta transaccional a la entidad emisora, sin incluir PAN completo ni CVV2.

La respuesta puede incluir:

- Estado de la creación.
- card_id.
- card_token, si aplica.
- Código de respuesta.
- Mensaje funcional.
- correlationId.

14. Auditoría y trazabilidad

Durante todo el flujo se debe registrar auditoría técnica y funcional sin incluir datos sensibles.

La auditoría debe contemplar como mínimo:

- Canal de origen: batch o API.
- Entidad emisora.
- Identificador del proceso.
- Identificador del registro, si aplica.
- card_id.
- Resultado de creación de cliente.
- Resultado de creación de tarjeta.
- Resultado de consulta a Pomelo.
- Resultado del cifrado en HSM.

- Resultado de persistencia.
- Estado final del proceso.
- Timestamp.
- Usuario técnico o cliente API.
- IP de origen, cuando aplique.
- correlationId.

La auditoría no deberá registrar:

- PAN completo.
- CVV2.
- Payload completo de Pomelo.
- Datos sensibles en claro.
- Respuestas completas que contengan CHD.

15. Manejo de errores y reprocesos

El flujo debe contemplar escenarios de error técnico o funcional, incluyendo:

- Error en validación de archivo o payload.
- Error al crear cliente en Pomelo.
- Error al crear tarjeta en Pomelo.
- Error al consultar datos sensibles en Pomelo.
- Error al cifrar PAN en HSM.
- Error al persistir en Oracle.
- Timeout o indisponibilidad de Pomelo.
- Timeout o indisponibilidad del HSM.
- Error de idempotencia o duplicidad.

Ante cualquier error relacionado con datos sensibles, el sistema debe garantizar:

- No persistir PAN en claro.
- No persistir CVV2.
- No registrar datos sensibles en logs.
- No generar archivos temporales con datos sensibles.
- Mantener trazabilidad suficiente para análisis y reproceso controlado.
- Evitar duplicidad de clientes o tarjetas.

Los reprocesos deberán realizarse con base en identificadores de control, estado del proceso e idempotencia, no con base en PAN en claro ni CVV2.

16. Cierre del proceso

El proceso finaliza cuando la tarjeta queda creada y persistida con los datos protegidos, o cuando el sistema registra un estado de error seguro que permita análisis o reproceso posterior.

El resultado esperado del flujo exitoso es:

- Cliente creado en Pomelo y en prepago Credibanco.
- Tarjeta creada en Pomelo y en prepago Credibanco.
- card_id y card_token persistidos.
- PAN cifrado en Oracle.
- Identificador protegido de búsqueda del PAN persistido.
- Últimos 4 dígitos y BIN persistidos para operación.
- Fecha de vencimiento protegida según definición aprobada.
- CVV2 descartado sin almacenamiento.
- Auditoría registrada sin datos sensibles.
- Estado de tarjeta actualizado correctamente.

Tratamiento propuesto por tipo de dato

Dato	Tratamiento	Almacenamiento	Observación
PAN completo	Cifrado inmediato mediante HSM con AES-256-GCM	Oracle: pan_encrypted	Nunca se almacena en claro.
Identificador de búsqueda del PAN	HMAC-SHA-256 con llave secreta custodiada	Oracle: pan_hmac	Recomendado sobre SHA-256 simple.
Últimos 4 dígitos	Extracción antes del cifrado	Oracle: last_four	Permitido para operación y visualización parcial.
BIN	Extracción antes del cifrado	Oracle: bin	Necesario para ruteo, reglas y clasificación.
Fecha de vencimiento	Cifrado recomendado	Oracle: exp_date_encrypted	Recomendado cifrar por postura conservadora.
Card token Pomelo	Almacenamiento como token del proveedor	Oracle: card_token	No debe permitir reconstruir PAN.
CVV2	Descarte inmediato	No se almacena	No debe persistirse, registrarse ni enviarse a otros componentes.

Riesgos identificados

Riesgo	Descripción	Mitigación propuesta
Exposición de PAN en claro	El PAN se recibe desde Pomelo durante la consulta de datos sensibles.	Cifrado inmediato mediante HSM, no logging, no caché, no archivos, limpieza de memoria y persistencia solo cifrada.
Almacenamiento accidental de CVV2	El CVV2 recibido desde Pomelo podría quedar persistido por error.	Descarte inmediato, exclusión de modelos persistentes, filtros de logging, pruebas negativas y validación AppSec.
Uso de SHA-256 simple para PAN	Un hash simple del PAN puede ser vulnerable a ataques por diccionario si se filtra la base de datos.	Usar HMAC-SHA-256 con llave secreta custodiada en HSM/KMS.
Fecha de vencimiento almacenada en claro	La fecha puede incrementar el riesgo de correlación con otros datos de tarjeta.	Almacenar fecha de vencimiento cifrada, salvo aprobación explícita de Seguridad.
Logging accidental de payloads Pomelo	Interceptores HTTP o trazas podrían registrar PAN/CVV2.	Sanitización de logs, deshabilitar logging de payloads sensibles, pruebas de observabilidad y mascaramiento.
Falla del HSM durante cifrado	Si el HSM no está disponible, el PAN no podría cifrarse.	No persistir PAN en claro. Fallar de forma segura, registrar evento y permitir reproceso controlado.
Persistencia inconsistente	La tarjeta podría quedar creada en Pomelo, pero no persistida correctamente en Oracle.	Idempotencia, estados transitorios, reconciliación, manejo de compensaciones y auditoría.

Exposición en memoria	El PAN existe temporalmente en memoria del proceso.	Reducir ventana al mínimo, limpiar referencias, evitar dumps, deshabilitar logs debug y controlar heap dumps.
Acceso indebido a Oracle	Usuarios técnicos podrían acceder a datos protegidos.	Mínimo privilegio, segregación de funciones, auditoría, cifrado, controles administrativos y monitoreo.
Uso indebido del card token	El token de Pomelo podría usarse indebidamente para consultar datos sensibles.	Control de acceso, cifrado si aplica, autorización estricta, monitoreo y segregación.
Reprocesos batch duplicados	Un archivo reprocesado podría generar duplicidad de tarjetas.	Idempotencia por archivo, registro, entidad, correlación y estado de procesamiento.
Falta de evidencia PCI	Sin evidencia técnica, el control puede no ser aceptado en auditoría.	Generar evidencias de cifrado, descarte CVV2, sanitización de logs, HSM, accesos, pruebas y trazabilidad.

Aplicaciones y/o soluciones afectadas

Aplicación / solución	Impacto
Entidad emisora – Canal batch	Origina solicitudes de creación de tarjetas mediante archivos enviados por SFTP. Debe ajustarse al formato definido para creación de tarjetas y recibir respuestas sin exposición de PAN completo ni CVV2.
Entidad emisora – Canal API	Consume los endpoints de creación de tarjetas expuestos por Credibanco. Debe autenticarse y enviar solicitudes bajo los esquemas de seguridad, validación e idempotencia definidos.
SFTP Server	Canal de recepción de archivos batch desde la entidad emisora. Debe operar dentro del esquema seguro de transferencia definido para archivos de entrada y salida.
GoAnywhere MFT	Solución responsable de detectar, validar estructura/formato y mover los archivos batch hacia el almacenamiento de procesamiento. Debe garantizar trazabilidad, control de transferencia y manejo seguro de archivos.
File Storage	Repositorio utilizado para almacenar archivos batch de entrada, salida y respuesta. Debe evitar almacenar archivos con PAN completo o CVV2 dentro de este flujo de creación, salvo diseños posteriores formalmente aprobados.
Prepaid Portal Gateway	Gateway de entrada para solicitudes API. Debe realizar autenticación, validación de esquema, control de firma/hash, trazabilidad y logging sanitizado para evitar exposición de datos sensibles.
SSO / Identity Provider	Solución de autenticación que valida clientes o consumidores autorizados para invocar APIs de creación de tarjetas, cuando aplique.

Prepaid Batch Create Processor	Componente responsable de leer archivos batch, validar registros, controlar duplicidad, gestionar estados de procesamiento y enviar solicitudes al Orchestrator. Debe aplicar trazabilidad sin registrar datos sensibles.
Prepaid Card Creation API	API responsable de recibir solicitudes transaccionales de creación de tarjetas. Debe validar payload, entidad, producto, idempotencia y enviar la solicitud al Orchestrator sin registrar datos sensibles en logs.
Prepaid Card Creation Orchestrator	Componente central más impactado. Orquesta la creación de cliente, creación de tarjeta, consulta de datos sensibles en Pomelo, cifrado del PAN, generación del identificador protegido, descarte de CVV2 y persistencia segura. Debe operar dentro del alcance CDE propuesto.
Pomelo API Client	Cliente de integración encargado de consumir las APIs de Pomelo. Debe aplicar mTLS o canal seguro, timeout, retry controlado, circuit breaker y sanitización de logs para respuestas que contengan PAN/CVV2.
APIs Pomelo	Proveedor externo utilizado para crear cliente, crear tarjeta y consultar datos sensibles de la tarjeta. Su disponibilidad y respuesta son necesarias para completar el flujo.
HSM Thales payShield	Componente criptográfico responsable del cifrado del PAN mediante llave custodiada bajo HSM. Debe estar disponible antes de persistir la tarjeta y operar bajo controles de acceso, monitoreo y auditoría.
Oracle Database	Repositorio donde se persisten los datos permitidos y protegidos: pan_encrypted, pan_hmac, last_four, bin, exp_date_encrypted, card_id, card_token, estados y metadatos. No debe almacenar PAN en claro ni CVV2.
Módulo de auditoría / logging	Debe registrar eventos técnicos y funcionales del proceso sin incluir PAN, CVV2, payloads completos ni respuestas sensibles de Pomelo. Requiere sanitización y enmascaramiento.
Herramientas APM / observabilidad	Deben configurarse para no capturar payloads sensibles, headers sensibles, respuestas completas, variables de contexto con PAN/CVV2 ni trazas con CHD.
SIEM / plataforma de seguridad	Recibe eventos de seguridad y auditoría asociados al flujo. Debe conservar trazabilidad suficiente sin almacenar datos sensibles de tarjeta.
OpenShift / plataforma de contenedores	Plataforma donde se ejecutan los componentes de creación de tarjetas. Debe garantizar segregación, configuración segura, secretos protegidos, controles de red y trazabilidad de workloads dentro del CDE.
Gestor de secretos / configuración	Debe custodiar credenciales, certificados, llaves de integración y parámetros sensibles requeridos por los componentes, sin exponer secretos en variables inseguras, logs o archivos de configuración no protegidos.

WAF / seguridad perimetral	Aplica principalmente para el canal API. Debe proteger endpoints expuestos contra abuso, tráfico anómalo, ataques automatizados y patrones maliciosos.
Módulo de idempotencia y control de duplicidad	Debe garantizar que reintentos o reprocesos no generen duplicidad de clientes o tarjetas, especialmente en escenarios de timeout con Pomelo o fallas intermedias.
Proceso de conciliación / reconciliación	Puede verse impactado para resolver casos en los que Pomelo haya creado una tarjeta, pero el flujo local haya fallado antes de persistir correctamente los datos protegidos.

ANEXOS

<Se incluye documentos de referencia que hacen parte del diseño de Arquitectura >

<Autores: Arquitecto>

NOMBRE	OBSERVACIONES
	<Link de referencia del anexo>

Tabla 2.